

Order-Dependent Rejection Sampling in Rhyme-128:

Exact Secret-Tail Recovery and a Fresh-Message Forgery Using at Most 40,000 Signatures

Martin Feussner
Selmer Center, University of Bergen
`martin.feussner@uib.no`

1 October 2026

Provenance and review status. The attack was independently found by an AI system, OpenAI Codex using Daybreak Blue at maximum reasoning effort, without a human first proposing this specific attack. The AI also produced the derivation, implementation, experiments, adversarial review, and initial manuscript. At the date above, no human cryptanalyst has independently verified the argument, implementation, measurements, or novelty assessment. This preliminary disclosure is provided for human review and reproduction.

Abstract

Rhyme is a lattice signature submitted to the Next-generation Commercial Cryptographic Algorithms Program. Its coefficient rejection sampler scans a parity-constrained set “in a fixed order”, but the specification does not define that order. Appendix A states the correct cumulative-envelope requirement for its normalization constant, but then claims that the maximum occurs at the boundary and prescribes the resulting single-term closed form. For the operational Rhyme-128 CDT/source convention, exhaustive evaluation gives prescribed values $9.3573397 \cdot 10^{-6}$ and $1.4950374 \cdot 10^{-6}$ for the two challenge parities, while the required maxima are respectively 1.0019364869 and 1.0019292771. Reading the PDF’s displayed Gaussian definition and parameter table literally gives different numbers, but the same defect: boundary values 0.0075371423 and 0.0035191981 versus required maxima 1.1818109123 and 1.1821799192. In the operational completion tested here, combining the prescribed boundary values with a deterministic central-first order permitted by Algorithm 3 makes the sampled offset almost equal to the negative challenge. Each signature then gives a noisy linear observation of the four-polynomial secret tail.

We recover the exact 1,024 secret-tail coefficients by negacyclic least-squares regression and use the recovered public-key relation to forge at zero commitment. Two independent Rhyme-SHAKE-128 keys were tested on a four-core Intel Core i5-6500 with 16 GiB of RAM. The specification-tape run recovered at 40,000 signatures; an independent-rejection-randomness run recovered at 30,000. Both used a 50,000-signature collection, with the final 10,000 held out for diagnostics. An untouched submitted verifier accepted and decoded all 50,000 attack-oracle signatures in each run. Collection took 178.30 and 160.44 seconds, and the corresponding 40,000-signature batch recoveries took 9.87 and 6.97 seconds on the shared machine. In both runs, recovery and forgery without access to the target secret produced a 1,372-byte signature on a fresh message that the pristine submitted verifier accepted. Wrong-message, perturbed-tail, and wrong-key controls rejected.

The result has a narrow but security-critical scope. It is a practical chosen-message attack on a deterministic completion that uses the fixed order permitted by Algorithm 3 and the boundary value prescribed by Appendix A. The submitted source uses an ascending scan and sets $M = 1.002214572 \dots$, which satisfies the envelope for the operational CDT distribution; that sampler is not broken by this attack. A paired 50,000-signature control used the same key, messages, central order, and signing logic as Run 2, changing only M to

that operationally safe value. It failed the public-key check and recovered only 399 of 1,024 coefficients. The evidence establishes a specification/design-level defect and an internally inconsistent submitted specification. It does not establish that every implementation of the underlying abstract construction is broken.

1 Introduction

Fiat–Shamir-with-aborts signatures publish a response obtained by combining a random mask, a challenge, and a long-term secret. Rejection sampling is used to make the accepted response distribution independent of that secret. The normalization in such a sampler must dominate the complete acceptance mass for every possible mask. If it does not, a sequential implementation can cross probability one before scanning every candidate, and an otherwise irrelevant enumeration order becomes security-critical.

Rhyme uses a scalar rejection procedure for the first response component [1]. Algorithm 3 assigns a probability increment to each element of a finite parity set and scans the set “in a fixed order.” The order is left unspecified. Appendix A first states the correct cumulative envelope, but later asserts that a boundary point dominates its maximum and prescribes the single-term expression obtained there. Direct evaluation shows that this expression is five to six orders of magnitude smaller than the required cumulative envelope under the operational CDT convention and more than two orders of magnitude smaller under a literal reading of the PDF’s Gaussian convention.

Consider the fixed central-minus order

$$\begin{aligned} V_0 &= (0, -2, 2, -4, 4, \dots, -12, 12), \\ V_1 &= (-1, 1, -3, 3, \dots, -13, 13). \end{aligned}$$

This is a deterministic permutation of exactly the specified sets, fixed before the key, message, challenge, and signing randomness are known. With the prescribed boundary constant, an early central term normally exhausts the uniform threshold. The returned offset is therefore close to $v = -c$, where c is the public binary challenge polynomial. Rhyme’s bottom response then has the form

$$z_{\text{bot}} \approx y_{\text{bot}} - s_{\text{tail}}c.$$

The public challenges become regressors for the secret tail.

Our contributions are:

- We show under both the literal PDF convention and the operational CDT/source convention that Appendix A’s boundary closed form violates the exact cumulative-envelope condition stated earlier in that appendix.
- We identify a second proof error concerning shifted discrete Gaussian sums and delimit its role in the failure.
- We instantiate a fixed central-first order allowed by the submitted specification and derive a public negacyclic least-squares recovery algorithm.
- We give an exact zero-commitment forgery from any recovered short tail satisfying the public-key relation.
- We demonstrate exact recovery and pristine-verifier-accepted fresh-message forgeries for two independent Rhyme-SHAKE-128 keys on the machine identified in Section 6.
- We separate the specification defect from the submitted source repair and confirm on the same key that the regression fails after the operationally valid envelope is restored.

The recovered object is the exact four-polynomial secret tail used in the public relation, not the original 32-byte seed or the complete serialized signing key. The tail is nevertheless sufficient to produce valid signatures on arbitrary fresh messages through the zero-commitment construction in Section 5. We therefore use the terms *exact secret-tail recovery* and *fresh-message forgery* throughout.

Related public findings. As of 1 October 2026, the public Rhyme tracker lists three separate findings: two high-level security ceilings in the submitted 384- and 512-bit implementations and a missing doubled-width parity mask in the SM3 signers [2]. The third finding gives noisy parity equations but does not demonstrate key recovery or forgery. We found no public report of the invalid cumulative envelope, order-dependent sampler, or the attack described here. This is a best-effort novelty check, not a claim about unpublished or unindexed work.

2 Rhyme-SHAKE-128

Let

$$\mathcal{R} = \mathbb{Z}[x]/(x^{256} + 1), \quad q = 3329.$$

At Level 128, Rhyme uses $(k, \ell) = (2, 3)$ and $d = k + \ell - 1 = 4$. Write the short secret relation as

$$s = (1, s_{\text{tail}}), \quad s_{\text{tail}} = (s_1, s_2, s_3, s_4) \in \mathcal{R}^4.$$

The public verification matrix is

$$A = (-2b + qj \mid 2A_{\text{gen}} \mid 2I_k) \in \mathcal{R}_{2q}^{k \times (k+\ell)}, \quad (1)$$

where j selects the first public row. Key generation ensures

$$As = qj \pmod{2q}. \quad (2)$$

Each coefficient of the recovered tail lies in $[-2, 2]$ in the submitted parameter set.

For one signing attempt, Rhyme samples a top masking polynomial y_1 and constructs

$$y_{\text{bot}} = 2B_{\text{sig}}X' + e_{\text{bot}}. \quad (3)$$

Writing $\text{pk} = (\text{seed}_A, b_{\text{gen}})$, Algorithm 6 computes

$$\mu = H_{\text{gen}}(\text{seed}_A, b_{\text{gen}}, M), \quad w = Ay, \quad c = \text{SampleInBall}(w, \mu), \quad (4)$$

where c is binary with Hamming weight $\tau = 30$. The submitted Rhyme-SHAKE-128 source realizes Equation (4) by computing

$$\begin{aligned} \mu &= \text{SHAKE256}(\text{enc}(\text{pk}) \parallel M)[0 : \text{CRHBYTES}], \\ \tilde{c} &= \text{SHAKE256}(\text{pack}_w(w) \parallel \mu)[0 : \text{CTILDEBYTES}], \\ c &= \text{SampleChallenge}(\tilde{c}), \end{aligned} \quad (5)$$

and transmits $\tilde{c}$ together with the encoded response. Here $\text{enc}(\text{pk})$ is the submitted byte encoding of $(\text{seed}_A, b_{\text{gen}})$, and $[0 : L]$ denotes the first L output bytes. Algorithm 3 acts on every coefficient pair $(y_{1,i}, c_i)$ and returns

$$v_i = 2x_i + c_i.$$

With $v = (v_i)_i$, the transmitted response is

$$z_1 = y_1 + v, \quad z_{\text{bot}} = y_{\text{bot}} + s_{\text{tail}}v. \quad (6)$$

All products are negacyclic in $\mathcal{R}$. The verifier checks

$$w' = Az - qjc \pmod{2q} \quad (7)$$

and Algorithm 7 recomputes μ and checks $c = \text{SampleInBall}(w', \mu)$. The submitted source performs the corresponding bitwise $\tilde{c}$ comparison from Equation (5). At Level 128 the verifier also requires

$$\|z_1\|_\infty \leq 388, \quad \|z_{\text{bot}}\|_\infty \leq 581, \quad \|z\|_2^2 \leq 21,949,787. \quad (8)$$

The serialized secret key contains more material than s_{tail} , including the signing basis and a seed K . Our attack does not recover those bytes and does not invoke the ordinary signing algorithm after recovery. It recovers the actual tail in Equation (2), checks that relation publicly, and uses it to construct signatures directly.

3 The rejection-sampling defect

For challenge bit $c \in \{0, 1\}$, define

$$V_c = \{v \in \mathbb{Z} : |v| \leq R, v \equiv c \pmod{2}\}, \quad p_c(v) = \frac{\rho_{\sigma_{\text{tar}}}(v)}{\sum_{u \in V_c} \rho_{\sigma_{\text{tar}}}(u)}. \quad (9)$$

Rhyme-128 uses $R = 13$ and a first-component bound $B_1 = 388$. For a mask $y \in [-B_1 - R, B_1 + R]$, Algorithm 3 scans V_c in a fixed order. If $|y + v| \leq B_1$, it adds

$$a_y(v) = p_c(v) \frac{\rho_{\sigma_y}(y + v)}{M_c \rho_{\sigma_y}(y)} \quad (10)$$

to a cumulative value and returns the first v for which that value exceeds a uniform $r \in (0, 1)$.

Lemma 1 (Cumulative envelope). *For a fixed challenge bit c , the sequential intervals in Algorithm 3 can assign probability $a_y(v)$ to every eligible candidate only if*

$$M_c \geq \max_{|y| \leq B_1 + R} \sum_{\substack{v \in V_c \\ |y+v| \leq B_1}} p_c(v) \frac{\rho_{\sigma_y}(y + v)}{\rho_{\sigma_y}(y)}. \quad (11)$$

Proof. For fixed (y, c) , the intervals assigned to eligible candidates have total length

$$\frac{1}{M_c} \sum_v p_c(v) \frac{\rho_{\sigma_y}(y + v)}{\rho_{\sigma_y}(y)}.$$

If this exceeds one, later intervals lie partly or wholly outside the support of r . Their realized probabilities then depend on which candidates were scanned first and cannot equal all of the prescribed increments. Requiring the total length to be at most one for every eligible y and each parity c gives Equation (11). $\square$

Appendix A of the submitted specification explicitly states Equation (11). The defect is in its subsequent derivation. After introducing an upper bound over all integers and completing the square, the appendix treats

$$\Theta_\alpha(\delta) = \sum_{v \in \mathbb{Z}} e^{-\alpha(v+\delta)^2} \quad (12)$$

as translation invariant in δ . This is false for a noninteger shift. Poisson summation gives

$$\Theta_\alpha(\delta) = \sqrt{\frac{\pi}{\alpha}} \sum_{k \in \mathbb{Z}} e^{-\pi^2 k^2 / \alpha} \cos(2\pi k \delta),$$

Table 1: Prescribed boundary constants and exhaustive cumulative-envelope maxima under the two Gaussian conventions.

Convention	c	$M_{\text{bdry},c}$	$M_{\text{req},c}$	$\arg \max_y$
Operational CDT/source	0	$9.3573397 \cdot 10^{-6}$	1.0019364869	$\{-378, 378\}$
	1	$1.4950374 \cdot 10^{-6}$	1.0019292771	$\{-377, 377\}$
Literal PDF	0	0.0075371423	1.1818109123	$\{-380, 380\}$
	1	0.0035191981	1.1821799192	$\{-379, 379\}$

which is periodic and is maximized at integer δ , rather than constant. Indeed,

$$\Theta_\alpha(0) - \Theta_\alpha(1/2) = 4\sqrt{\frac{\pi}{\alpha}} \sum_{\substack{k \geq 1 \\ k \text{ odd}}} e^{-\pi^2 k^2 / \alpha} > 0.$$

The difference is far below the displayed numerical precision for the operational parameters. Replacing the false equality by the valid inequality $\Theta_\alpha(\delta) \leq \Theta_\alpha(0)$ preserves the appendix’s loose universal upper-bound step, so this error alone does not produce the attack.

The security-critical step comes next. Appendix A evaluates the original restricted sum where only one candidate is eligible at the extreme boundary, asserts that this point dominates every interior y , and prescribes

$$M_{\text{bdry},c} = p_c(R_c) \frac{\rho_{\sigma_y}(B_1)}{\rho_{\sigma_y}(B_1 + R_c)}, \quad (13)$$

where R_c is the largest element of V_c . This is one summand at one boundary mask. Exhaustive evaluation disproves the claimed dominance.

The displayed PDF formulas and the operational source instantiate different Gaussian conventions. Appendix A literally defines

$$\rho_s(x) = e^{-\pi x^2 / s^2}. \quad (14)$$

For Rhyme-128, Table 3 lists $\sigma/(2\sqrt{\pi}) = 1.295870$ and $\sigma_y = 122$, while the sampler text sets $\sigma_{\text{tar}} = 2\sigma$. Reading these statements literally gives

$$\sigma_{\text{tar}} = 4\sqrt{\pi} (1.295870) = 9.187479087 \dots$$

The submitted source instead treats 122 and 2.591740 as ordinary standard deviations. Its operational weights are therefore

$$\rho_y^{\text{op}}(x) = e^{-x^2/(2 \cdot 122^2)}, \quad p_c^{\text{op}}(v) \propto e^{-v^2/(2 \cdot 2.591740^2)}, \quad (15)$$

as confirmed independently by the CDT and Q63 tables.

Table 1 evaluates Equation (11) under both conventions, always retaining the submitted $R = 13$ and $B_1 = 388$. Every integer $y \in [-401, 401]$ and every eligible $v \in V_c$ was evaluated. The operational values were also recomputed directly from the source’s fixed-point Q63 probability table and Q62 exponential evaluator; they agree to every digit displayed.

Thus Appendix A’s boundary-dominance claim fails under either interpretation. The submitted source sets $M = 1.002214572 \dots$. This exceeds both required *operational* maxima in the first two rows, but it is below both maxima under the literal PDF convention. Every later statement that calls this source value “safe” refers only to the operational CDT/source distribution. The end-to-end experiments likewise use Equation (15); they do not claim to instantiate and test a separate literal-PDF signer.

3.1 Why the fixed order becomes a leakage channel

With a valid envelope, the total assigned probability mass is at most one and the cumulative intervals lie in $[0, 1]$; the realized output law is then independent of their scan order. With $M_{\text{bdry},c}$, central candidates often contribute more than the entire available threshold range. Under the central-minus order, the first candidate is $v = 0$ for $c = 0$ and $v = -1$ for $c = 1$. Thus

$$v = -c + \delta, \quad (16)$$

where the deviation δ is rare enough in the accepted transcript that averaging exposes the secret.

Algorithm 3 says only to scan V_c “in a fixed order.” No other part of the submitted specification fixes that order, so the central-minus permutation is a permitted deterministic choice fixed independently of the key and target secret. The violation of the stated envelope and the resulting order dependence follow from Lemma 1 and Table 1. The magnitude and correlation of the remaining error after all signing gates are empirical properties of this completion. Sections 4 and 6 test those properties using only signatures accepted and decoded by the pristine submitted verifier.

4 Public secret-tail recovery

For transcript t , let C_t be the 256×256 negacyclic convolution matrix of its public challenge polynomial c_t . For bottom row r , substitution of Equation (16) into Equation (6) gives the exact decomposition

$$z_{t,r} = -C_t s_r + n_{t,r} + D_t s_r, \quad (17)$$

where $n_{t,r} = y_{\text{bot},t,r}$ and D_t is convolution by δ_t . Define the aggregate error $\epsilon_{t,r} = n_{t,r} + D_t s_r$. We do not assume that either summand, or their sum after all signing gates, has exactly zero mean or is independent of C_t . Least squares is a heuristic dominant-term approximation whose adequacy is assessed by public-key checks, held-out residuals, and the end-to-end forgery experiment.

The ordinary least-squares estimate is

$$\hat{s}_r = - \left(\sum_t C_t^\top C_t \right)^{-1} \left(\sum_t C_t^\top z_{t,r} \right). \quad (18)$$

Negacyclic convolution diagonalizes at the odd 512th roots of unity. Let $\hat{c}_{t,j}$ and $\hat{z}_{t,r,j}$ be the corresponding Fourier coordinates. Then Equation (18) is evaluated componentwise as

$$\hat{s}_{r,j} = - \frac{\sum_t \overline{\hat{c}_{t,j}} \hat{z}_{t,r,j}}{\sum_t |\hat{c}_{t,j}|^2}. \quad (19)$$

An inverse negacyclic FFT followed by coefficientwise rounding gives an integer candidate $\tilde{s}_{\text{tail}}$.

The attack needs only values available from an ordinary signature:

1. decode the signature response and derive c_t from its transmitted challenge hash;
2. append $(c_t, z_{\text{bot},t})$ to the normal equations;
3. at a public checkpoint, evaluate Equation (19) and round;
4. use Equation (2) as an algebraic screen; and
5. construct the fresh-message response, check its response and norm bounds and encodability, and accept the candidate only if the pristine verifier accepts the resulting signature.

The public relation alone is not a certificate of forging capability: the candidate's constructed response must also satisfy the verifier's bounds and the submitted encoding. The attack therefore stops only after both the public relation and a fresh-message verification succeed. A candidate has no standing merely because its coefficients are small or its residual is favorable. Post hoc comparison with withheld truth determines whether the accepted candidate is the original tail. In the reported runs, the specification-tape candidate first passed these tests at 40,000 signatures; the independent-randomness candidate first passed at 30,000.

Equation (19) can be accumulated online with $O(dn)$ complex state and $O(Tdn \log n)$ arithmetic for T signatures. The reported reference implementation instead uses a batch array for simplicity; its memory use is reported in Section 6.

5 Fresh-message forgery

The recovered tail gives a direct, deterministic forgery. Let M^* be a message not submitted to the signing oracle and parse $\mathbf{pk} = (\text{seed}_A, b_{\text{gen}})$. At the specification level, Algorithm 7 requires

$$\mu^* = H_{\text{gen}}(\text{seed}_A, b_{\text{gen}}, M^*), \quad c^* = \text{SampleInBall}(0, \mu^*). \quad (20)$$

For the submitted Rhyme-SHAKE-128 verifier, compute the exact byte-level instantiation

$$\begin{aligned} \mu^* &= \text{SHAKE256}(\text{enc}(\mathbf{pk}) \parallel M^*)[0 : \text{CRHBYTES}], \\ \tilde{c}^* &= \text{SHAKE256}(\text{pack}_w(0) \parallel \mu^*)[0 : \text{CTILDEBYTES}], \\ c^* &= \text{SampleChallenge}(\tilde{c}^*). \end{aligned} \quad (21)$$

This is the source implementation of Equation (20). Set

$$z^* = (c^*, s_{\text{tail}}c^*) \quad (22)$$

and call the submitted `pack_sig` routine on $(\tilde{c}^*, z^*)$ to obtain the ordinary API signature.

Theorem 2 (Zero-commitment forgery). *Let s_{tail} have coefficients in $[-2, 2]$ and satisfy Equation (2). Then the signature in Equation (22) passes Rhyme's verification equation for M^* . For the submitted Level-128 coefficient bounds, it also passes every response norm bound.*

Proof. Writing $s = (1, s_{\text{tail}})$ and using commutativity of multiplication in $\mathcal{R}$, the verifier reconstructs

$$Az^* - qjc^* = (As - qj)c^* = 0 \pmod{2q}.$$

It therefore recomputes the zero commitment used to derive $\tilde{c}^*$. More explicitly, the submitted verifier obtains $c^* = \text{SampleChallenge}(\tilde{c}^*)$, reconstructs $w' = 0$, and recomputes

$$\tilde{c}' = \text{SHAKE256}(\text{pack}_w(0) \parallel \mu^*)[0 : \text{CTILDEBYTES}] = \tilde{c}^*.$$

Thus its bitwise challenge-seed comparison succeeds.

The challenge has 30 coefficients equal to one and the rest zero. Since each coefficient of s_{tail} has magnitude at most two, every coefficient of each product $s_r c^*$ has magnitude at most 60. Hence

$$\|z_1^*\|_\infty \leq 1, \quad \|z_{\text{bot}}^*\|_\infty \leq 60, \quad \|z^*\|_2^2 \leq 30 + 4 \cdot 256 \cdot 60^2 = 3,686,430.$$

These are below all three limits in Equation (8). $\square$

The construction does not recover K , regenerate the original serialized secret key, search for a hash collision, or call the signing oracle after recovery. It forges each chosen target message directly.

6 Machine-local end-to-end experiments

6.1 Platform and source provenance

All results in this section were generated on the same desktop: a four-core Intel Core i5-6500 at 3.20 GHz with 16 GiB of RAM, running 64-bit Linux. The software environment used GCC 13.3.0, Python 3.13.13, and NumPy 2.5.3. The machine was shared with other audit jobs, so wall time varied with system load and filesystem cache state.

The official candidate archive had SHA-256

7b509d21c6674bc23751b8743cb7c2a4a07ee295faf04e2fa95c0613160bdfd,

and the specification had SHA-256

b1d6f86e7b2ce58a54e3078396c0df2283c59ae7773b3513580a19a8cb3c9ae3.

All 49 files in the pristine Rhyme-SHAKE-128 tree used for external verification were byte-identical to the corresponding files in that archive.

The tested signing completion made the following choices:

1. retain the operational CDT/source distributions and use the two parity-specific values of $M_{\text{bdry},c}$ obtained by applying Appendix A’s prescribed formula to those distributions;
2. traverse the specified parity sets in the fixed central-minus order; and
3. if the submitted first-response encoder cannot represent an otherwise accepted response, report encoding failure and let the signer’s existing loop restart.

The last rule addresses a separate source-level coverage gap without changing an entropy frequency or the submitted decoding format. The signer retained the submitted entropy tables. A preliminary extended-table variant was discarded after its outputs failed pristine verification; none of its measurements are used as attack-oracle evidence. Consequently, every emitted oracle signature could be passed to a verifier linked entirely against the untouched submitted source. The external verifier also decoded the response used to create each public recovery record; the recovery experiment did not rely on a modified decoder.

Algorithm 6 explicitly supplies the same tape *rt2* to both the sampling of X' and SAMPLE Z. In the operational source mapping, Run 1 therefore used the same stream identifier for the first component of X' and for rejection thresholds. Run 2 changed only that rejection-stream identifier to an unused domain. This removes the direct random-stream reuse between the thresholds and the first X' component while retaining the invalid boundary M , central-minus order, and all surrounding signing logic. The two runs used distinct deterministic DRNG seeds and no shared state, so their per-signature pseudorandom streams were separate across processes. Deterministic seeds make the experiment reproducible; the recovery process received neither seed and read only public transcripts.

6.2 Protocol

For each attack run, a fresh key was generated and 50,000 distinct messages were signed. The pristine submitted verifier accepted and decoded 50,000/50,000 emitted attack-oracle signatures in each run, with zero verification or decoding failures. Recovery records were generated only from those pristine-decoded signatures. The first 40,000 records formed a common comparison prefix and the last 10,000 were held out. Before recovery, the scoring secret was removed from the attack prefix. Recovery and forgery then ran with no secret file present; their outputs were hashed before the scoring secret was restored for post hoc comparison.

The experimental collector generated all 50,000 signatures before running the regression in order to reserve a held-out suffix. The attack computations used only the stated prefixes.

Table 2: Exact rounded secret-tail coefficients out of 1,024.

Signatures	Run 1: reused tape	Run 2: independent tape	Paired safe- M
10,000	995	989	380
20,000	1,021	1,022	400
30,000	1,023	1,024	399
40,000	1,024	1,024	399

Because both the public relation and final verification are public stopping tests, a prospective execution can run them at the same fixed checkpoints and stop after 40,000 queries in Run 1 or 30,000 in Run 2; no held-out signature or target-secret diagnostic is needed.

The held-out residual is a diagnostic only. It was not used for model selection or stopping. At public checkpoints the attack tested the rounded tail against Equation (2), constructed the fresh-message response, checked its bounds and encoding, and submitted it to the pristine verifier.

6.3 Recovery results

Table 2 reports post hoc coefficient scores. Truth was used only to populate this table; it was not an estimator input. In Run 1, the 30,000-signature candidate failed Equation (2), while the 40,000-signature candidate passed the relation and forged. In Run 2, the 30,000-signature candidate already passed and forged; its exactness persisted at 40,000.

At 40,000 signatures, Run 1 had coefficient RMSE 0.120619 and maximum unrounded error 0.426050. Run 2 had RMSE 0.115143 and maximum error 0.382580. Their held-out residual RMS values were respectively 124.218685 and 124.661083, compared with zero-model values 124.332177 and 124.770305. No zero-mean premise is inferred from these measurements; they show empirically that the $-C_{tsr}$ term is recoverable by averaging for the two tested keys.

Collection of all 50,000 signatures took 178.30 seconds for Run 1 and 160.44 seconds for Run 2, or 280.43 and 311.64 emitted, pristine-accepted signatures per second. The corresponding 40,000-signature batch recoveries took 9.87 and 6.97 seconds. Peak recovery memory was 2.52 GiB in both runs. The online accumulation described after Equation (19) removes this batch-memory cost.

6.4 Encoding-restart measurement

The submitted first-response table has 96 high symbols and three raw low bits. With center 388, it represents $z_1 \in [-388, 379]$ but has no escape symbol for the verifier-allowed values 380, ..., 388. We instrumented the guard at that exact condition and separately counted every other `pack_sig` failure. While producing 50,000 emitted signatures, Run 1 restarted 5,696 times solely at this guard and Run 2 restarted 5,578 times. These are respectively 10.23% and 10.04% of all candidates that reached the packing stage, or 11.39 and 11.16 encoder-only restarts per 100 emitted signatures; neither run had another packing failure. The gate is therefore non-negligible and selects against the positive z_1 tail. The instrumented replays produced byte-identical public keys and oracle files to the two reported attack collections.

To test whether that selection creates the recovery signal, we repeated Run 2 on the same key and messages with a diagnostic full-range first-response table, so no otherwise accepted response was restarted by this gate. This table is incompatible with the pristine decoder, so the resulting signatures are used only for this leakage ablation and are not counted as attack-oracle signatures. The ungated regression recovered 988, 1,021, 1,024, and 1,024 exact coefficients at 10,000, 20,000, 30,000, and 40,000 signatures. At 30,000 its coefficient RMSE was 0.134043, compared with 0.131398 for the pristine-encodable Run 2 transcript; both tails were already

exact. The ungated recovered tail also satisfied the public relation and produced a pristine-verifier-accepted fresh-message forgery. Thus the restart gate slightly changes sample selection but does not account for the recovery channel in this paired experiment.

6.5 Forgeries and controls

The recovered tails matched all 1,024 separately retained scoring coefficients byte for byte. The pristine verifier accepted a fresh-message forgery for each run:

Run	Signature bytes	Squared norm	Pristine verification
1	1,372	28,464	accept
2	1,372	28,636	accept

The signing-query messages contained a fixed prefix followed by a counter; the 28-byte forgery message was absent from both query sets. Three controls were run for each key: the forgery under another message, a signature formed after changing one recovered coefficient, and the forgery under an independently generated public key. All six checks rejected.

For Run 1, the public key, 50,000-record pristine-decoded transcript, recovered tail, and pristine-codec forgery have SHA-256 values

```
18cb64be10afa7d869870c62bd32c9b314af9078711dd9cb9882dbe0c9ce2246,
29abbbf892d1706907fe1caf6fbeeabba61c96856e1c402cba2baaf9a4ef70d0bf,
01e3e36399fc89aa7c806e75cad5146abdd67c324384c51cfe793652719746b7,
38fb4b7ecfa6939504de183287fa596b6cc45c84c69b1f049f637f64bffa154f.
```

For Run 2, the corresponding values are

```
a1d5d5b475e275baabfc894acbb42064575efeb843b3170e7fbf5003b40cc6b2,
d97c47f98e2cb8a0c0cb4fae225ce5f720e60df97ca5bc52d00c4b163ebc7dba,
de72d6d1e48747e7aa5d06dbc25a82bd8a1a5ef1384a3423f4202044065375a1,
8f663a36111e357ca5f7a7d106f81a051362d3dc6801f6f2a4ea0af72ff72113.
```

6.6 Paired safe-envelope control

The safe- M control was rerun with exactly the same key and ordered messages as Run 2; the public-key files are byte-identical. It retained the central-minus order, independent rejection stream, submitted entropy tables, encoding-failure restart, and all surrounding signing logic. A source diff between the two instrumented signers contains one behavior-changing edit: the sampler uses the source’s $M = 1.002214572 \dots$ instead of the two operational boundary values. The pristine verifier accepted and decoded 50,000/50,000 emitted control signatures.

The paired control incurred 2,603 encoder-only restarts while producing those 50,000 signatures, or 4.95% of the 52,603 candidates reaching the packing stage; it had no other packing failure. Applying the same regression to the first 40,000 signatures produced an all-zero rounded candidate. Only 399 of its 1,024 coefficients happened to match the secret; its coefficient RMSE was 0.971998 and its maximum unrounded error was 2.318174. The held-out residual RMS and zero-model RMS were both 129.564098 to the displayed precision. The public relation failed and the attempted forgery was rejected. This same-key, one-variable ablation is consistent with correcting M removing the particular first-moment channel exploited here. It remains one empirical control and does not prove the corrected implementation secure against every possible attack.

7 Scope, limitations, and repair

The result gives an end-to-end EUF-CMA adversary against the tested Rhyme-SHAKE-128 completion: using a prefix of at most 40,000 chosen-message signatures, it outputs an accepted signature for a message outside the full 50,000-message experimental query set. Its measured time, memory, and query costs are practical on the tested four-core desktop. The experimental collector’s held-out suffix is excluded from the adversary’s input, as described in Section 6.

The following qualifications delimit that statement.

- The submitted specification does not define a unique scan order. It states the correct envelope condition but subsequently prescribes a boundary closed form that violates it. The attack targets the deterministic central-first completion described above.
- The unmodified submitted SHAKE source is not the vulnerable signer. It chooses ascending arrays and uses an envelope that is safe for its operational CDT distributions. The same numerical value is not an envelope under the literal PDF Gaussian convention.
- The submitted first-response encoder does not cover every value allowed by the verification bounds. The tested completion treats an unencodable response as a signing restart, without modifying the submitted entropy tables. Every reported oracle signature was accepted and decoded by pristine submitted code. This gate is non-negligible, but the same-key ungated diagnostic recovered at the same 30,000-signature checkpoint, so the gate was not needed for recovery in that comparison.
- End-to-end recovery was tested at the 128-bit parameter set on two independent keys. Two successes do not estimate a key-averaged success probability or establish sample complexity at higher levels.
- The practical signing experiment uses the operational Gaussian distributions encoded by the submitted CDT and fixed-point tables. The literal PDF convention gives the separate values in Table 1. Its boundary formula is also invalid, but no end-to-end experiment is claimed for a literal-PDF signer.
- The attack recovers the exact secret tail, not the original seed or every byte of the serialized signing key.

The specification should replace Equation (13) by the exact maximum in Equation (11) or by a proved upper bound. It should test the resulting cumulative mass, specify a canonical enumeration order, domain-separate every random tape, define one Gaussian parameter convention, and require lossless encoding for every response accepted by verification. The security proof and parameter tables should then be recomputed for that single corrected sampler.

8 Conclusion

The submitted specification states the correct cumulative-envelope requirement, but then derives and prescribes a boundary closed form that violates that requirement for the submitted Rhyme-128 parameters. Together with the unspecified fixed enumeration order, the invalid constant makes the sampler order-dependent. In the tested central-first operational completion, the public response became a recoverable noisy linear observation of the secret tail. On this machine, two independent Level-128 tails were recovered from at most 40,000 pristine-accepted signatures and yielded accepted fresh-message forgeries through the pristine verifier. The same-key control using the operationally valid source envelope was consistent with removal of this regression channel, and an ungated diagnostic showed that the encoder restart was not needed for recovery in the paired comparison. These results establish a practical break of the

tested completion and a specification/design-level defect in an internally inconsistent submitted specification. They do not claim that every implementation of the underlying abstract Rhyme construction is broken; in particular, the submitted source’s operationally safe envelope lies outside this attack.

References

- [1] Zhongxiang Zheng, Anyu Wang, Chunhuan Zhao, Guangwu Xu, Sibofeng, Zhichen Yan, Yuhang Sun, Zhengtao Jiang, Congming Wei, Shuang Sun, Chen Jia, and Shuaigang Li. *RHYME: Algorithm Specifications and Supporting Documentation*. Submission sign-22 to the Next-generation Commercial Cryptographic Algorithms Program, 2026.
- [2] ngcc.dev. *Rhyme (sign-22): public security findings*. <https://ngcc.dev/reports/sign-22.html>, accessed 1 October 2026.